CompTIA Security+ (Exam SY0-601)

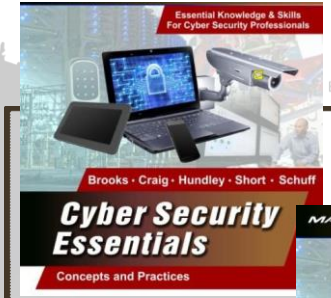
CSS3423 Computer and Cyber Security
Semester Sept Session 2024/25

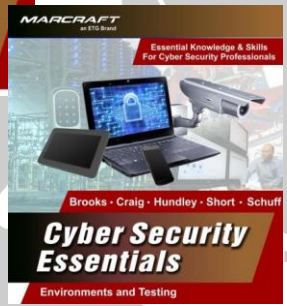
CYBERSEC FIRST RESPONDER®

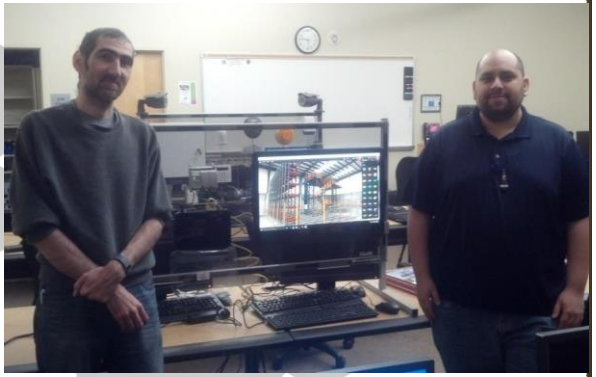
CompTIA

MARCRAFT
an ETG Brand

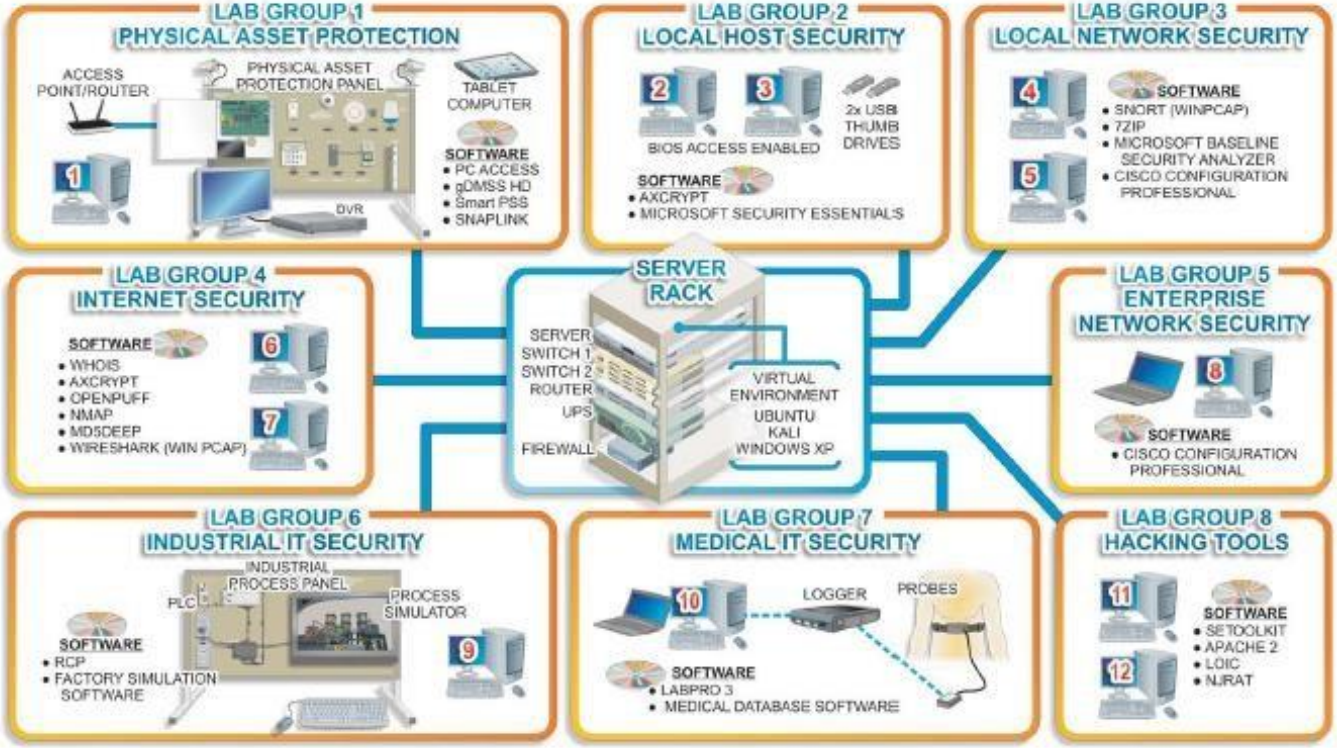
MARCRAFT
an ETG Brand







Cyber Security Essentials Concepts & Practices



24 STUDENTS - 20 HOURS PER LAB GROUP

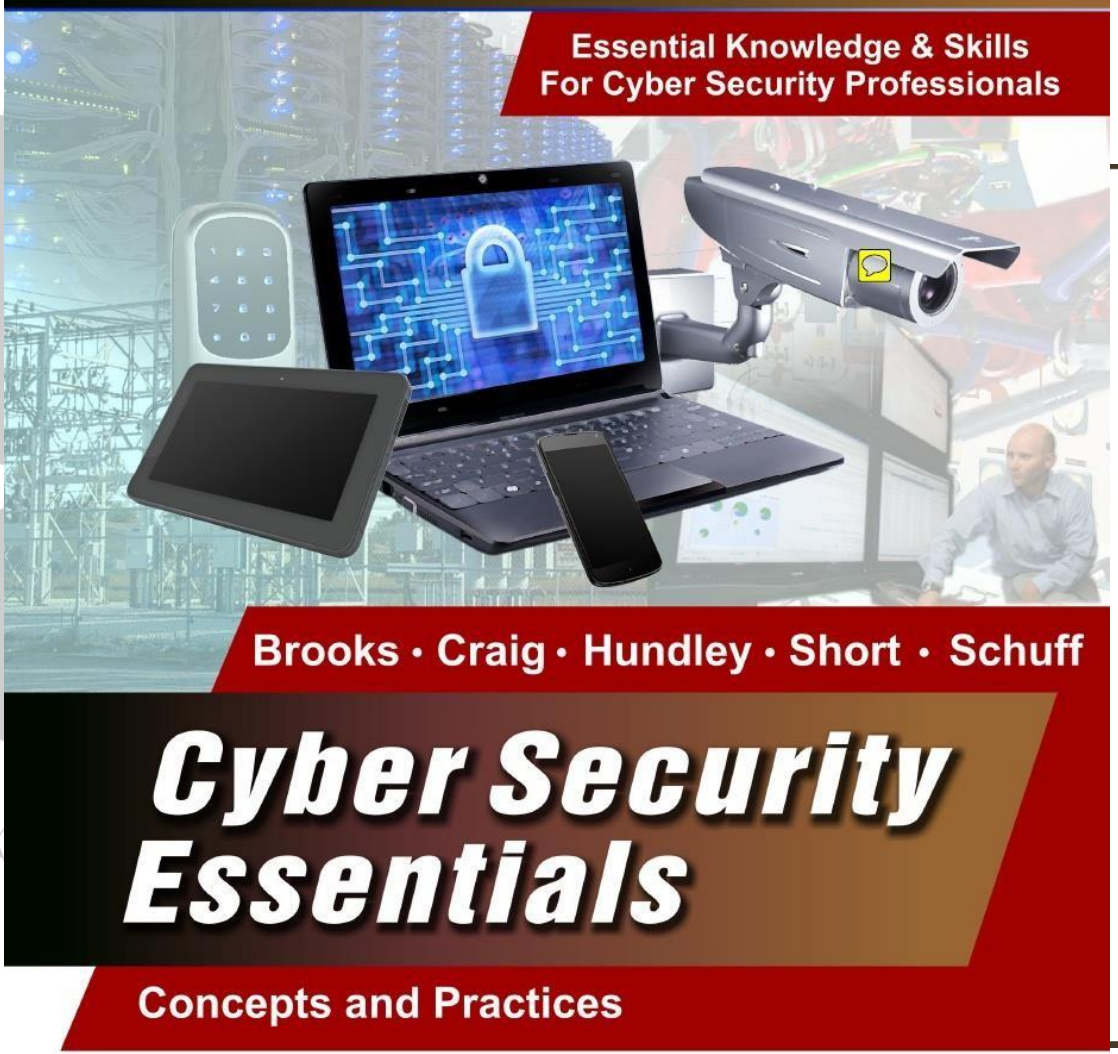
Prepares students to Challenge:

ISACA Cybersecurity Fundamentals Certificate Exam

Microsoft Security Fundamentals MTA 98-367 Exam

CompTIA Security+

MARCRAFT
an ETG Brand


Essential Knowledge & Skills
For Cyber Security Professionals
Brooks · Craig · Hundley · Short · Schuff
Cyber Security Essentials
Concepts and Practices

MERCRAFT

MARCRAFT
an ETG Brand

Essential Knowledge & Skills
For Cyber Security Professionals

Brooks • Craig • Hundley • Short • Schuff

Cyber Security Essentials

Environments and Testing

Course Objectives (1)

- Compare security roles and security controls
- Explain threat actors and threat intelligence
- Perform security assessments and identify social engineering attacks and malware types
- Summarize basic cryptographic concepts and implement public key infrastructure
- Implement authentication controls
- Implement identity and account management controls

CompTIA Security+ | Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved. | CompTIA.org

Course Objectives (2)

- Implement secure network designs, network security appliances, and secure network protocols
- Implement host, embedded/Internet of Things, and mobile security solutions
- Implement secure cloud solutions
- Explain data privacy and protection concepts
- Perform incident response and digital forensics
- Summarize risk management concepts and implement cybersecurity resilience
- Explain physical security

CompTIA Security+ | Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved. | CompTIA.org

Lesson 1

Comparing Security Roles and Security Controls

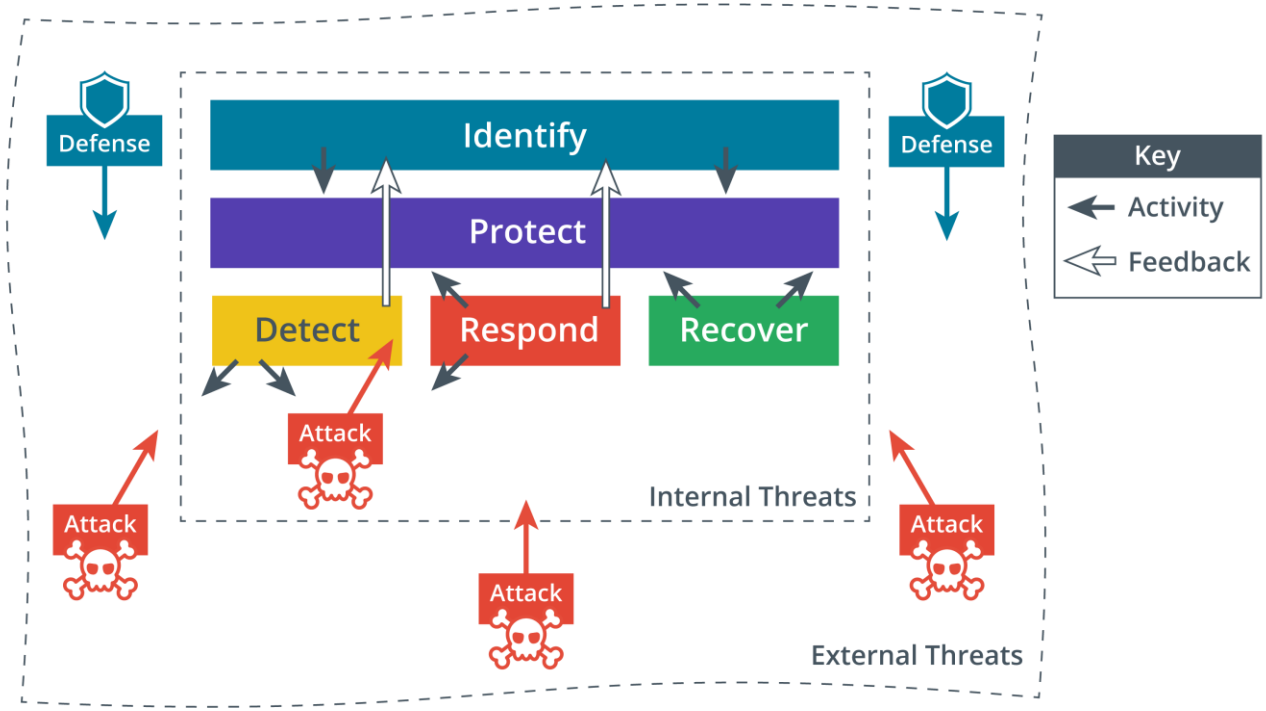
CompTIA®

Information Security

- CIA Triad
- Confidentiality
  - Information should only be known to certain people
- Integrity
  - Data is stored and transferred as intended and that any modification is authorized
- Availability
  - Information is accessible to those authorized to view or modify it
- Non-repudiation
  - Subjects cannot deny creating or modifying data

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Cybersecurity Framework



Information Security Competencies

- Risk assessments and testing
- Specifying, sourcing, installing, and configuring secure devices and software
- Access control and user privileges
- Auditing logs and events
- Incident reporting and response
- Business continuity and disaster recovery
- Security training and education programs

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Information Security Roles and Responsibilities

Image credit: Shannon Fagan © 123rf.com.

- Overall responsibility
  - Chief Security Officer (CSO)
  - Chief Information Security Officer (CISO)
- Managerial
- Technical
  - Information Systems Security Officer (ISSO)
- Non-technical
- Due care/liability

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Information Security Business Units

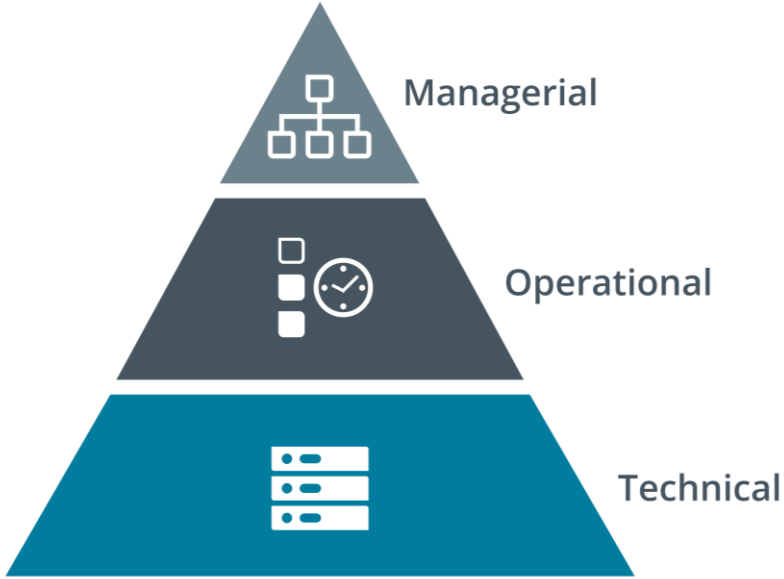
- Security Operations Center (SOC)
- DevSecOps
  - Development, security, and operations
- Incident response
  - Cyber incident response team (CIRT)
  - Computer security incident response team (CSIRT)
  - Computer emergency response team (CERT)

Image credit: John Mattern/Feature Photo Service for IBM

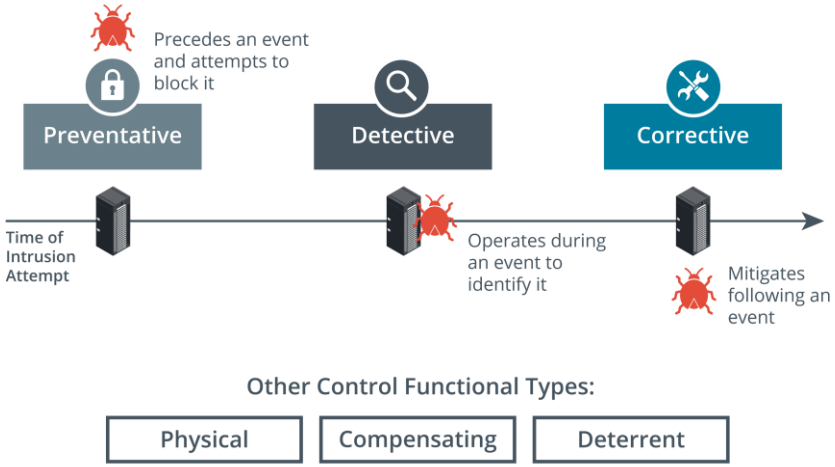
Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Security Control Categories

- Technical
  - Controls implemented in operating systems, software, and security appliances
- Operational
  - Controls that depend on a person for implementation
- Managerial
  - Controls that give oversight of the system



Security Control Functional Types (1)



Images © 123rf.com.

- Preventive
  - Physically or logically restricts unauthorized access
  - Operates before an attack
- Detective
  - May not prevent or deter access, but it will identify and record any attempted or successful intrusion
  - Operates during an attack
- Corrective
  - Responds to and fixes an incident and may also prevent its reoccurrence
  - Operates after an attack

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Security Control Functional Types (2)

- Physical
  - Controls such as alarms, gateways, and locks that deter access to premises and hardware
- Deterrent
  - May not physically or logically prevent access, but psychologically discourages an attacker from attempting an intrusion
- Compensating
  - Substitutes for a principal control

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

NIST Cybersecurity Framework

- Importance of frameworks
  - Objective statement of current capabilities
  - Measure progress towards a target capability
  - Verifiable statement for regulatory compliance reporting
- National Institute of Standards and Technology (NIST)
  - Cybersecurity Framework (CSF)
  - Risk Management Framework (RMF)
  - Federal Information Processing Standards (FIPS)
  - Special Publications

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

ISO and Cloud Frameworks

- International Organization for Standardization (ISO)
  - 21K information security standards
  - 31K enterprise risk management (ERM)
- Cloud Security Alliance
  - Security guidance for cloud service providers (CSPs)
  - Enterprise reference architecture
  - Cloud controls matrix
- Statements on Standards for Attestation Engagements (SSAE) Service Organization Control (SOC)
  - SOC2 evaluates service provider
    - Type I report assesses system design
    - Type II report assesses ongoing effectiveness
  - SOC3 public compliance report

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Benchmarks and Secure Configuration Guides

- Center for Internet Security (CIS)
  - The CIS Critical Security Controls
  - CIS-RAM (Risk Assessment Method)
- OS/network platform/vendor-specific guides and benchmarks
  - Vendor guides and templates
  - CIS benchmarks
  - Department of Defense Cyber Exchange
  - NIST National Checklist Program (NCP)
- Application servers and web server applications
  - Client/server
  - Multi-tier—front-end, middleware (business logic), and back-end (data)
  - Open Web Application Security Project (OWASP)

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Regulations, Standards, and Legislation

- Due diligence
  - Sarbanes-Oxley Act (SOX)
  - Computer Security Act (1987)
  - Federal Information Security Management Act (FISMA)
- General Data Protection Regulation (GDPR)
- National, territory, or state laws
  - Gramm–Leach–Bliley Act (GLBA)
  - Health Insurance Portability and Accountability Act (HIPAA)
  - California Consumer Privacy Act (CCPA)
- Payment Card Industry Data Security Standard (PCI DSS)

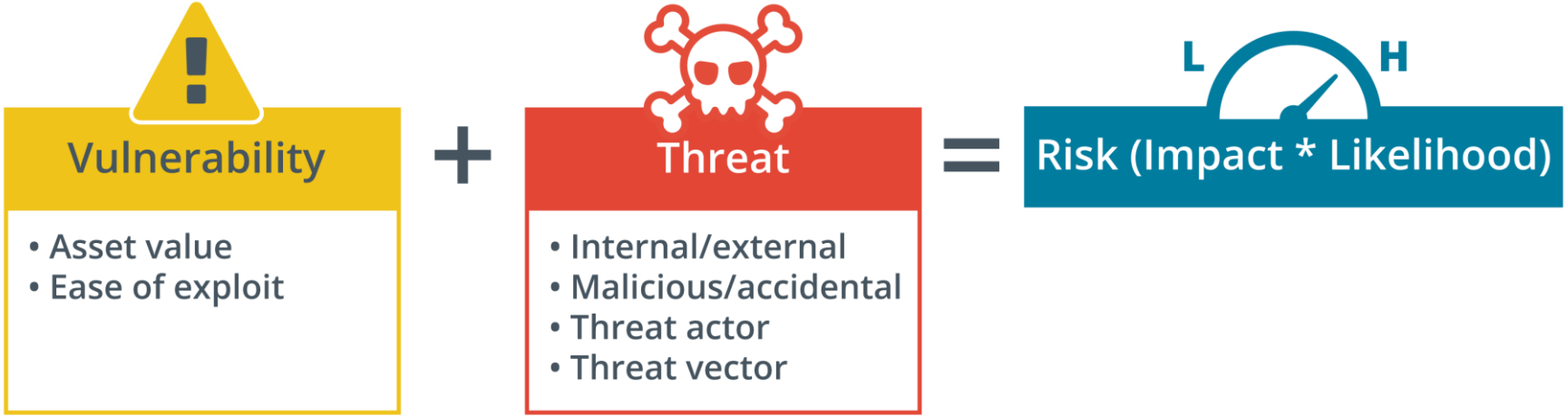
Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Lesson 2

Explaining Threat Actors and Threat Intelligence

CompTIA®

Vulnerability, Threat, and Risk



Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Attributes of Threat Actors

- Known threats versus adversary behaviors
- Internal/external
- Intent/motivation
  - Maliciously targeted versus opportunistic
  - Accidental/unintentional
- Level of sophistication
  - Resources/funding
  - Adversary capability levels

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

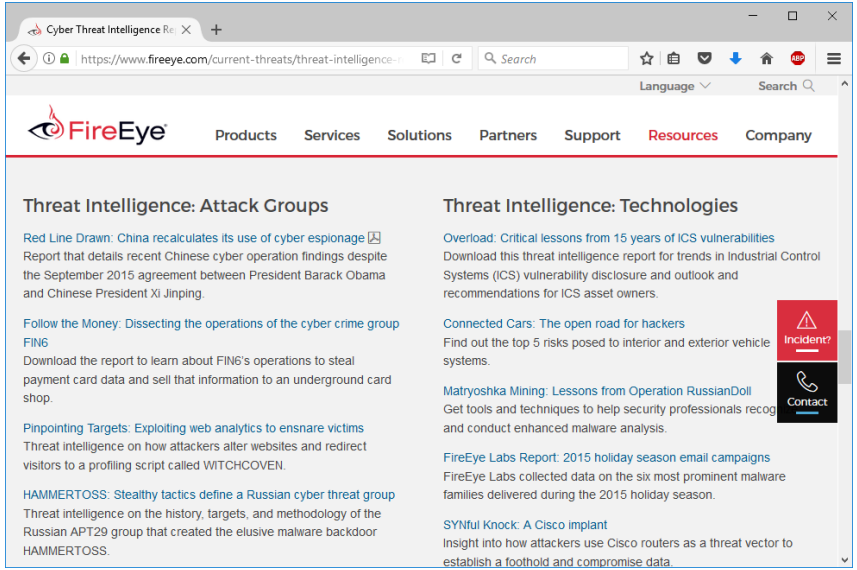
Hackers, Script Kiddies, and Hacktivists

- The “Lone Hacker”
  - White hats versus black hats versus gray hats
  - Authorized versus non-authorized versus semi-authorized
- Script kiddies
- Hacker teams and hacktivists

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

State Actors and Advanced Persistent Threats

- State-backed groups
  - Attached to military/secret services
  - Highly sophisticated
- Advanced Persistent Threat (APT)
- Espionage and strategic advantage
- Deniability
- False flag operations



Screenshot used with permission from fireeye.com.

Criminal Syndicates and Competitors

- Criminal syndicates
  - Operate across legal jurisdictions
  - Motivated by criminal profit
  - Can be very well resourced and funded
- Competitors
  - Cyber espionage
  - Combine with insider threat

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Insider Threat Actors

- Malicious insider threat
  - Has or has had authorized access
  - Employees, contractors, partners
  - Sabotage, financial gain, business advantage
- Unintentional insider threat
  - Weak policies and procedures
  - Weak adherence to policies and procedures
  - Lack of training/security awareness
  - Shadow IT

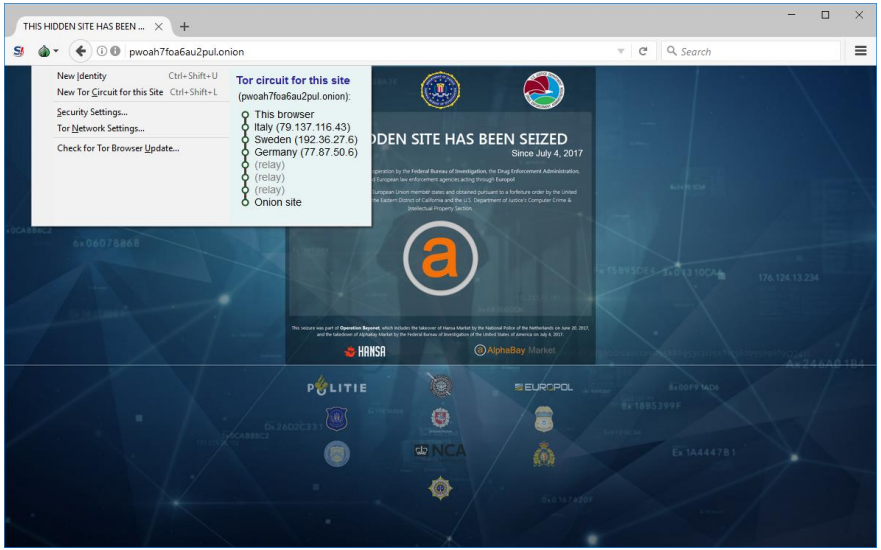
Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Attack Surface and Vectors

- Attack surface
  - Points where an attacker can discover/exploit vulnerabilities in a network or application
- Vectors
  - Direct access
  - Removable media
  - Email
  - Remote and wireless
  - Supply chain
  - Web and social media
  - Cloud

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Threat Research Sources



- Counterintelligence
- Tactics, techniques, and procedures (TTPs)
- Threat research sources
  - Academic research
  - Analysis of attacks on customer systems
  - Honeypots/honeynets
  - Dark nets and the dark web

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Threat Intelligence Providers

- Narrative analysis and commentary
- Reputation/threat data feeds—cyber threat intelligence (CTI)
- Platforms and feeds
  - Closed/proprietary
  - Vendor websites
  - Public/private information sharing centers
  - Open source intelligence (OSINT) threat data sources
- OSINT as reconnaissance and monitoring

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Other Threat Intelligence Research Sources

- Academic journals
- Conferences
- Request for Comments (RFC)
- Social media

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

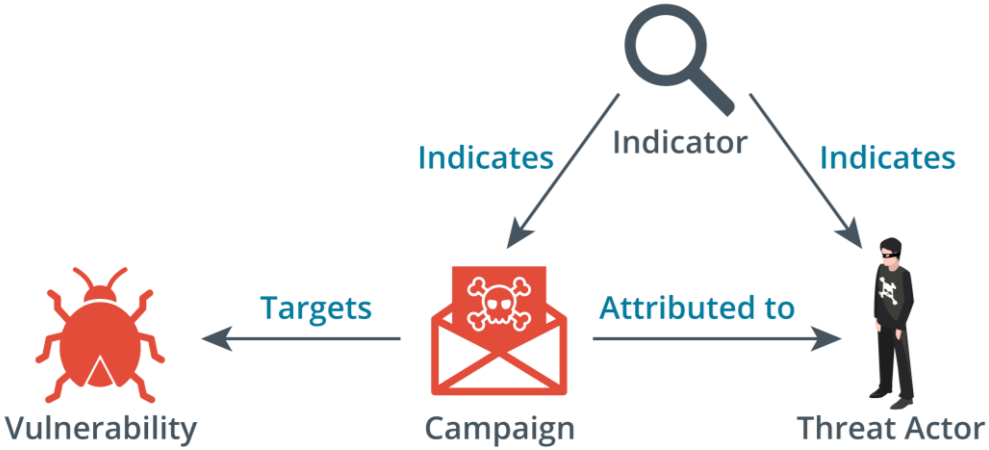
Tactics, Techniques, and Procedures and Indicators of Compromise

- Tactics, Techniques, and Procedures (TTPs)
  - Generalized statement of adversary behavior
  - Campaign strategy and approach (tactics)
  - Generalized attack vectors (techniques)
  - Specific intrusion tools and methods (procedures)
- Indicator of compromise (IoC)
  - Specific evidence of intrusion
  - Individual data points
  - Correlation of system and threat data
  - AI-backed analysis
  - Indicator of attack (IoA)

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Threat Data Feeds

- Structured Threat Information exchange (STIX)
- Trusted Automated Exchange of Indicator Information (TAXII)
- Automated Indicator Sharing (AIS)
- Threat maps
- File/code repositories
- Vulnerability databases and feeds



Icon images © Copyright 2016 Bret Jordan. Licensed under the Creative Commons Attribution-ShareAlike (CC BY-SA) License, Version 4.0. (freetaxii.github.io/stix2-icons.html.

Artificial Intelligence and Predictive Analysis

- Correlation between security intelligence/event monitoring and threat data
- Artificial intelligence (AI) and machine learning (ML)
  - Expert systems
  - Artificial neural networks (ANN)
    - Inputs, outputs, and feedback
    - Objectives and error states
- Predictive analysis
  - Threat forecasting
  - Monitor “chatter”

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Lesson 3

Performing Security Assessments

CompTIA®

ipconfig, ping, and arp

- Footprinting the network layout and rogue system detection
- ipconfig/ifconfig/ip
  - Report the local IP configuration
- ping
  - Test connectivity with a host
  - Use a ping sweep to detect live hosts on a subnet
- arp
  - Address Resolution Protocol (ARP) cache
  - Shows IP to Media Access Control (MAC) address mapping
  - Detect spoofing (validate MAC of default gateway)

```
C:\Users\Admin>for /l %i in (1,1,255) do @ping -n 1 -w 100 10.1.0.%i | find /i "
reply"
Reply from 10.1.0.1: bytes=32 time<1ms TTL=128
Reply from 10.1.0.128: bytes=32 time<1ms TTL=128
Reply from 10.1.0.129: bytes=32 time<1ms TTL=128
Reply from 10.1.0.131: bytes=32 time<1ms TTL=128
Reply from 10.1.0.132: bytes=32 time=1ms TTL=128
Reply from 10.1.0.134: bytes=32 time<1ms TTL=128

C:\Users\Admin>_
```

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

route and traceroute

- route
  - Show the local routing table
  - Identify default route and local subnet
  - Check for suspicious entries
- tracert/traceroute
  - Test the path to a remote host
- pathping/mtr
  - Measure latency

```
[centos@lx1 ~]$ route -n
Kernel IP routing table
Destination     Gateway         Genmask         Flags Metric Ref    Use Iface
0.0.0.0         10.1.0.254      0.0.0.0         UG    100    0        0 eth0
10.1.0.0        0.0.0.0         255.255.255.0   U     100    0        0 eth0
```

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

IP Scanners and Nmap

- Host discovery
  - Test whether host in IP range responds to probes
- Port scan
  - Test whether TCP or UDP port allows connections

```
C:\Program Files (x86)\Nmap>nmap 10.1.0.0/24
Starting Nmap 7.70 ( https://nmap.org ) at 2020-01-06 10:13 Pacific Standard Time
Nmap scan report for DC1.corp.515support.com (10.1.0.1)
Host is up (0.00s latency).
Not shown: 986 filtered ports
PORT     STATE SERVICE
53/tcp   open  domain
80/tcp   open  http
88/tcp   open  kerberos-sec
135/tcp  open  msrpc
139/tcp  open  netbios-ssn
389/tcp  open  ldap
443/tcp  open  https
445/tcp  open  microsoft-ds
464/tcp  open  kpasswd5
593/tcp  open  http-rpc-epmap
636/tcp  open  ldapssl
3268/tcp open  globalcatLDAP
3269/tcp open  globalcatLDAPssl
3389/tcp open  ms-wbt-server
MAC Address: 00:15:5D:01:CA:AB (Microsoft)
```

Screenshot used with permission from nmap.org.

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Service Discovery and Nmap

- Service discovery
  - Scan custom TCP/UDP port ranges
- Service and version detection
  - Fingerprinting each port
  - Protocol
  - Application/version
  - OS type
  - Device type

```
C:\Program Files (x86)\Nmap>nmap 10.1.0.1 -A
Starting Nmap 7.70 ( https://nmap.org ) at 2020-01-06 10:41 Pacific Standard Time
Nmap scan report for DC1.corp.515support.com (10.1.0.1)
Host is up (0.000083s latency).
Not shown: 986 filtered ports
PORT     STATE SERVICE       VERSION
53/tcp   open  domain?
| fingerprint-strings:
|   DNSVersionBindReqTCP:
|     version
|_    bind
80/tcp   open  http          Microsoft IIS httpd 10.0
| http-methods:
|_  Potentially risky methods: TRACE
|_http-server-header: Microsoft-IIS/10.0
|_http-title: IIS Windows Server
...
1 service unrecognized despite returning data. If you know the service/version, please sub
SF-Port53-TCP:V=7.70%I=7%D=1/6%Time=5E137F54%P=i686-pc-windows-windows%r(D
SF:NSVersionBindReqTCP,20,"\0\x1e\0\x06\x81\x04\0\x01\0\0\0\0\0\0\x07versi
SF:on\x04bind\0\0\x10\0\x03");
MAC Address: 00:15:5D:01:CA:AB (Microsoft)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1
Device type: general purpose
Running (JUST GUESSING): Microsoft Windows 2016|2012 (98%)
OS CPE: cpe:/o:microsoft:windows_server_2016 cpe:/o:microsoft:windows_server_2012:r2
Aggressive OS guesses: Microsoft Windows Server 2016 (98%), Microsoft Windows Server 2012
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Host: DC1; OS: Windows; CPE: cpe:/o:microsoft:windows
```

Screenshot used with permission from nmap.org.

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

netstat and nslookup

- netstat
  - Report port status on local machine
  - Switches to filter by protocol
  - Display process name or PID that opened port
- nslookup and dig
  - Query name servers
  - Zone transfers

Screenshot used with permission from Microsoft.

```
C:\Users\Administrator>netstat | findstr "10.1.0"
  TCP    10.1.0.1:80            ROGUE:1415             TIME_WAIT
  TCP    10.1.0.1:80            GATEWAY:49161          ESTABLISHED
  TCP    10.1.0.1:135           ROGUE:1417             TIME_WAIT
  TCP    10.1.0.1:135           ROGUE:ms-sql-s         TIME_WAIT
  TCP    10.1.0.1:139           ROGUE:1418             TIME_WAIT
  TCP    10.1.0.1:445           10.1.0.134:49226       ESTABLISHED
  TCP    10.1.0.1:49154         ROGUE:1467             ESTABLISHED
  TCP    10.1.0.1:49155         ROGUE:1468             ESTABLISHED
  TCP    10.1.0.1:49158         ROGUE:1469             ESTABLISHED
  TCP    10.1.0.1:49159         ROGUE:1470             ESTABLISHED
  TCP    10.1.0.1:49163         ROGUE:1471             ESTABLISHED

C:\Users\Administrator>_
```

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Other Reconnaissance and Discovery Tools

- theHarvester
  - Collate open source intelligence (OSINT)
- dnsenum
  - Collate DNS hosting information, name records, and IP schemas
- scanless
  - Collate results from third-party port scanning sites
- curl
  - Craft and submit protocol requests
- Nessus
  - Perform automated vulnerability scanning

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

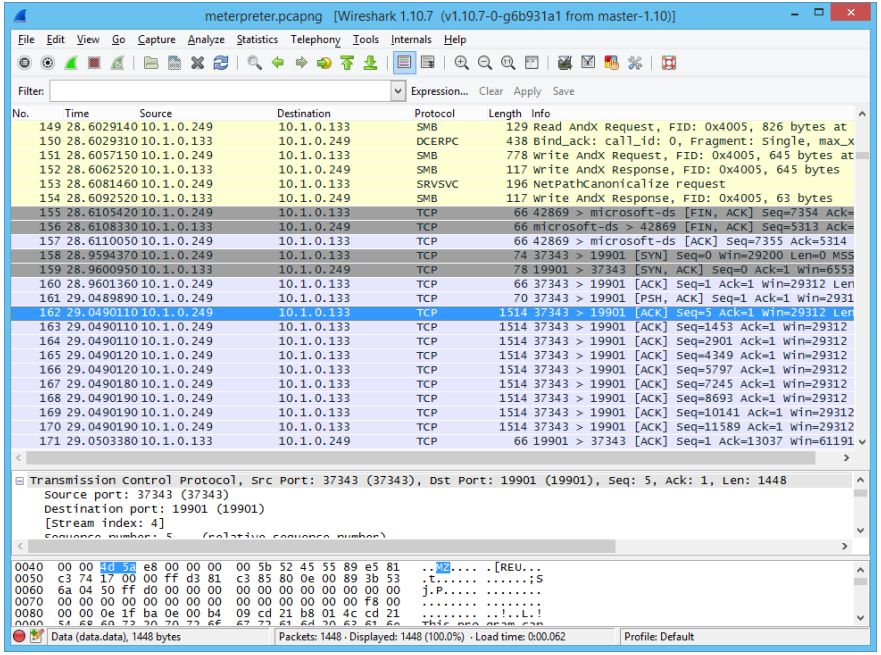
Packet Capture and tcpdump

- Packet analysis versus protocol analysis
- Sniffer—tool for capturing network frames
  - Use software to interact with host network driver (libpcap/winpcap)
  - Mirrored ports/switched port analyzer (SPAN)
  - Use a test access port (TAP) device to read frames from network media
  - Placement of sensors
- tcpdump
  - Write to pcap
  - Read from pcap
  - Filters

```
tcpdump -i eth0 "src host 10.1.0.100 and (dst port 53 or dst port 80)"
```


CompTIA Security+ Lesson 3 | Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved. | CompTIA.org

Packet Analysis and Wireshark



Screenshot used with permission from wireshark.org.

- Output panes
  - Packet list
  - Packet details (headers and fields)
  - Packet bytes (hex and ASCII)
- Capture and display filters
- Coloring rules
- Follow TCP Stream

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

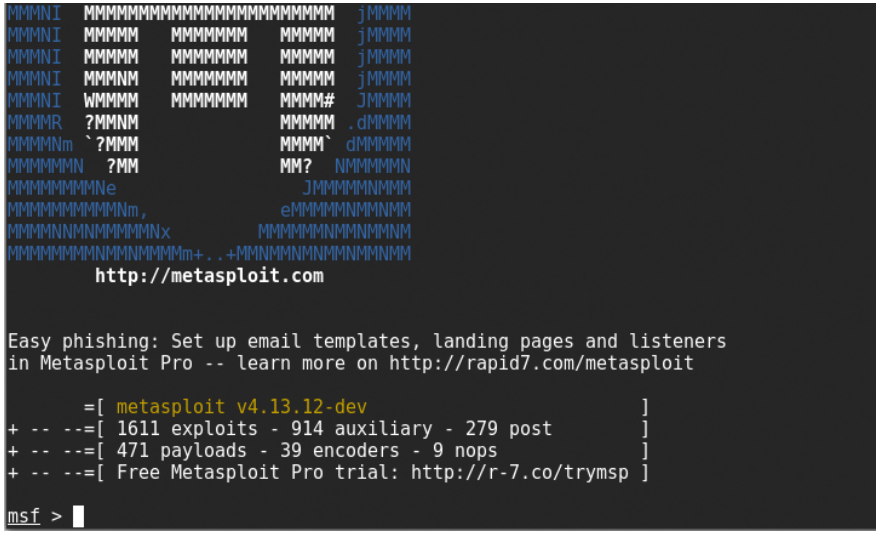
Packet Injection and Replay

- Packet injection
  - Crafting spoofed packets
  - Dsniff, Ettercap, Scapy
- hping
  - Host/port detection and firewall testing
  - Traceroute
  - Denial of service (DoS)
- tcpreplay
  - Stream a packet capture through an interface
  - Sandbox analysis and intrusion detection testing

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Exploitation Frameworks

- Simulate adversary tools for exploitation and backdoor access
- Metasploit
  - Modules to exploit known code vulnerabilities
  - Couple exploit module with payload
  - Obfuscate code to evade detection
- Sn1Per
  - Penetration test reporting and evidence gathering
  - Run automated suites of tests
- Other frameworks
  - Linux, embedded, browser, web/mobile app, cloud, ….



Screenshot used with permission from metasploit.com

Netcat

- Simple tool capable of very wide range of network tasks
- Port scanning and fingerprinting
- Command prompt listener over arbitrary port
- File transfer over arbitrary port

```
echo "head" | nc 10.1.0.1 -v 80
```

```
nc -l -p 666 -e cmd.exe
```

```
type accounts.sql | nc 10.1.0.192 6666
```

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

IPv4 CIDR Chart

K = 1,024 • M = 1,048,576

IP Addresses	Bits	Prefix	Subnet Mask
1	0	/32	255.255.255.255
2	1	/31	255.255.255.254
4	2	/30	255.255.255.252
8	3	/29	255.255.255.248
16	4	/28	255.255.255.240
32	5	/27	255.255.255.224
64	6	/26	255.255.255.192
128	7	/25	255.255.255.128
256	8	/24	255.255.255.0
512	9	/23	255.255.254.0
1 K	10	/22	255.255.252.0
2 K	11	/21	255.255.248.0
4 K	12	/20	255.255.240.0
8 K	13	/19	255.255.224.0
16 K	14	/18	255.255.192.0
32 K	15	/17	255.255.128.0
64 K	16	/16	255.255.0.0
128 K	17	/15	255.254.0.0
256 K	18	/14	255.252.0.0
512 K	19	/13	255.248.0.0
1 M	20	/12	255.240.0.0
2 M	21	/11	255.224.0.0
4 M	22	/10	255.192.0.0
8 M	23	/9	255.128.0.0
16 M	24	/8	255.0.0.0
32 M	25	/7	254.0.0.0
64 M	26	/6	252.0.0.0
128 M	27	/5	248.0.0.0
256 M	28	/4	240.0.0.0
512 M	29	/3	224.0.0.0
1024 M	30	/2	192.0.0.0
2048 M	31	/1	128.0.0.0
4096 M	32	/0	0.0.0.0

RIPE NCC
RIPE NETWORK COORDINATION CENTRE

ripe.net

Contact Registration Services: **hostmaster@ripe.net** • **lir-help@ripe.net**

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Topic 3B

Explain Security Concerns with General Vulnerability Types

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Software Vulnerabilities and Patch Management

- Exploits for faults in software code
- Applications
  - Different impacts and exploit scenarios
  - Client versus server apps
- Operating system (OS)
  - Obtain high level privileges
- Firmware
  - PC firmware
  - Network appliances and Internet of Things devices
- Improper or weak patch management
  - Undocumented assets
  - Failed updates and removed patches

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Zero-day and Legacy Platform Vulnerabilities

- Zero-day
  - Vulnerability is unknown to the vendor
  - Threat actor develops an exploit for which there is no patch
  - Likely to be used against high value targets
- Legacy platform
  - Vendor no longer releases security patches

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Weak Host Configurations

- Default settings
  - Vendor may not release product in a default-secure configuration
- Unsecured root accounts
  - Threat actor will gain complete control
  - Limit ability to login as superuser
- Open permissions
  - Configuration errors allowing unauthenticated access
  - Allowing write access when only read access is appropriate

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Weak Network Configurations

- Open ports and services
  - Restrict using an access control list
  - Disable unnecessary services or block ports
  - Block at network perimeter
- Unsecure protocols
  - Cleartext data transmissions are vulnerable to snooping and eavesdropping
- Weak encryption
  - Storage and transport encryption
  - Key is generated from a weak password
  - Cipher has weaknesses
  - Key distribution is not secure
- Errors
  - Error messages that reveal too much information

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Impacts from Vulnerabilities

- Data breaches and data exfiltration impacts
  - Data breach is where confidential data is read or transferred without authorization
  - Data exfiltration is the methods and tools by which an attacker transfers data without authorization
- Identity theft
  - Abuse of data from privacy breaches
- Data loss and availability loss impacts
  - Availability is also a critical security property
- Financial and reputation impacts

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Third-Party Risks

- Supply chains
  - Due diligence
  - Weak links
- Vendor management
  - Process for selecting suppliers and evaluating risks
  - System integration
  - Lack of vendor support
- Outsourced code development
- Data storage
- Cloud-based versus on-premises risks

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Topic 3C

Summarize Vulnerability Scanning Techniques

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Security Assessment Frameworks

- Methodology and scope for security assessments
- NIST SP 800-115
  - Testing
  - Examining
  - Interviewing
- Vulnerability assessment versus threat hunting and penetration testing
- Vulnerability assessments can use a mix of manual procedures and automated scanning tools

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Vulnerability Scan Types

- Automated scanners configured with list of known vulnerabilities
- Network vulnerability scanner
  - Configured with tests for most types of network hosts
  - Focused on scanning OS plus some desktop and server applications
- Application and web application scanners
  - Configured with application-specific tests

Screenshot used with permission from Greenbone Networks (openvas.org).

Common Vulnerabilities and Exposures

- Vulnerability feed/plug-in/test
- Security Content Automation Protocol (SCAP)
  - Mechanism for updating scanner via feed
  - Common identifiers
- Common Vulnerabilities and Exposures (CVE)
- Common Vulnerability Scoring System (CVSS)

Score	Description
0.1+	Low
4.0+	Medium
7.0+	High
9.0+	Critical

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

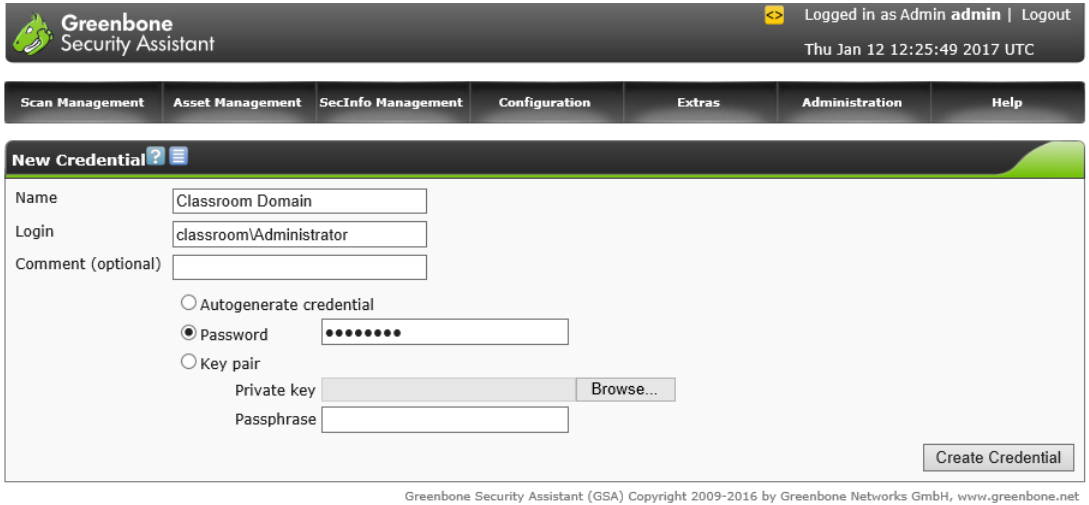
Intrusive versus Non-intrusive Scanning

- Remote scanning versus agent-based scanning
- Non-intrusive scanning
  - Passively test security controls
  - Scanners attach to network and only sniff traffic
  - Possibly some low-interaction with hosts (port scanning/banner grabbing)
- Intrusive/active scanning
  - Establish network session
  - Agent-based scan
- Exploitation frameworks
  - Highly intrusive/risk of system crash
  - Used with penetration testing

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Credentialed versus Non-credentialed Scanning

- Non-credentialed
  - Anonymous or guest access to host only
  - Might test default passwords
- Credentialed
  - Scan configured with logon
  - Can allow privileged access to configuration settings/logs/registry
  - Use dedicated account for scanning



Screenshot used with permission from Greenbone Networks (openvas.org).

False Positives, False Negatives, and Log Review

Information | Results (135 of 1148) | Hosts (1 of 254) | Ports (17 of 30) | Applications (19 of 44) | Operating Systems (1 of 6) | CVEs (48 of 48) | Closed CVEs (56 of 56) | TLS Certificates (3 of 5) | Error Messages (2 of 2) | User Tags (0)

1 - 10 of 135

Vulnerability	Severity ▼	QoD	Host IP	Host Name	Location	Created
Microsoft Windows Multiple Vulnerabilities (KB4457131)	10.0 (High)	80 %	10.1.0.1	DC1.corp.515support.com	general/tcp	Fri, Jan 3, 2020 9:58 PM UTC
Microsoft Windows Multiple Vulnerabilities (KB4467691)	10.0 (High)	80 %	10.1.0.1	DC1.corp.515support.com	general/tcp	Fri, Jan 3, 2020 10:20 PM UTC
Microsoft Windows Multiple Vulnerabilities (KB4471321)	10.0 (High)	80 %	10.1.0.1	DC1.corp.515support.com	general/tcp	Fri, Jan 3, 2020 10:40 PM UTC
Microsoft Windows Multiple Vulnerabilities (KB4512517)	10.0 (High)	80 %	10.1.0.1	DC1.corp.515support.com	general/tcp	Fri, Jan 3, 2020 10:27 PM UTC
Microsoft Malware Protection Engine on Windows Defender Multiple Remote Code Execution Vulnerabilities	9.3 (High)	97 %	10.1.0.1	DC1.corp.515support.com	general/tcp	Fri, Jan 3, 2020 10:19 PM UTC
Microsoft Malware Protection Engine on Windows Defender Multiple Vulnerabilities	9.3 (High)	80 %	10.1.0.1	DC1.corp.515support.com	general/tcp	Fri, Jan 3, 2020 10:09 PM UTC

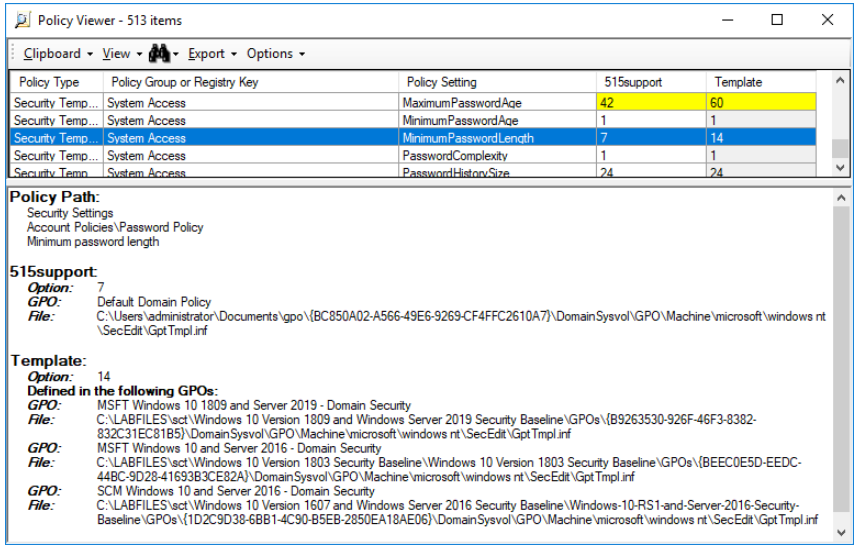
Screenshot used with permission from Greenbone Networks (openvas.org).

- Analyzing and validating scan report contents
- False positives
  - Scanner identifies a vulnerability that is not actually present
- False negatives
  - Scanner fails to identify a vulnerability
- Review logs to confirm results

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Configuration Review

- Lack of controls
  - Security controls that should be present but are not (or are not functioning)
- Misconfiguration
  - Settings deviate from template configuration
- Driven by templates of configuration settings
  - Open Vulnerability and Assessment Language (OVAL)
  - Extensible Configuration Checklist Description Format (XCCDF)
- Compliance-based templates available in many products



Screenshot used with permission from Microsoft.

Threat Hunting

- Use log and threat data to search for IoCs
- Advisories and bulletins
  - Plan threat hunting project in response to newly discovered threat
- Intelligence fusion and threat data
  - Use security information and event management (SIEM) and threat data feed to automate searches
- Maneuver
  - Consider possibility of alerting adversary to the search
  - Use techniques that will give positional advantage

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Topic 3D

Explain Penetration Testing Concepts

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Penetration Testing

- Pen test or ethical hacking
- Verify threat
  - Identify vulnerability and the vector by which it could be exploited
- Bypass security controls
  - Identify lack of controls or ways to circumvent existing controls
- Actively test security controls
  - Examine weaknesses that render controls ineffective
- Exploit vulnerabilities to prove threat exists (“pwned”)
- Active and highly intrusive techniques, compared to vulnerability assessment

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Rules of Engagement

- Agreement for objectives and scope
- Authorization to proceed from system owner and affected third-parties
- Attack profile
  - Black box (unknown environment)
  - White box (known environment)
  - Gray box (partially known environment—to model insider threat agents, for instance)
- Bug bounty programs

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Exercise Types

- Red team
  - Performs the offensive role
- Blue team
  - Performs the defensive role
- White team
  - Sets the rules of engagement and monitors the exercise
- Purple team
  - Exercise set up to encourage collaboration
  - Red and blue teams share information and debrief regularly
  - Might be assisted by a facilitator

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Passive and Active Reconnaissance

- Pen testing and kill chain attack life cycle
- Reconnaissance phase
  - Passive techniques unlikely to alert target
  - Active techniques are detectable
- Open Source Intelligence (OSINT)
- Social engineering
- Footprinting
- War driving
- Drones/unmanned aerial vehicle (UAV) and war flying

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Pen Test Attack Life Cycle

- Initial exploitation
  - Obtain a foothold via an exploit
- Persistence
  - Establish a command & control backdoor
  - Reconnect across host shut down/user log off events
- Privilege escalation
  - Internal reconnaissance
  - Gain additional credentials and compromise higher privilege accounts
- Lateral movement
  - Compromise other hosts
- Pivoting
  - Access hosts with no direct remote connection via a pivot host
- Actions on objectives
- Cleanup

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.